Security, Privacy and Compliance Plan

This is an engineering checklist, not legal advice or a certification. The business/client must confirm applicable Indian privacy and insurance obligations, insurer agreements, and required disclosures with qualified reviewers.

1. Assets and threats

Assets: member/customer data, quote history, premiums, credentials, active insurer sessions, screenshots, exported PDFs, branding/licence data, update channel and installers. Threats: untrusted insurer content reaching app privileges; secrets in logs/source; unauthorized local access; incorrect parsing; tampered installer/update; data left after retention; unapproved automation.

2. Electron controls

- Disable renderer Node integration.
- Enable context isolation.
- Expose only allowlisted preload methods; never expose raw IPC.
- Validate all IPC inputs in main process.
- Restrict navigation and handle unexpected popups explicitly.
- Use restrictive CSP for app-owned UI.
- Keep remote insurer content isolated from privileged APIs.
- Review installed Electron version security guidance before release.

3. Credentials and sessions

- No production credentials in source, fixtures, docs, screenshots, or command-line args.
- OS-backed secure storage only for saved credentials.
- No plaintext fallback if secure storage is unavailable.
- Never log passwords, OTPs, tokens, cookies or authorization headers.
- Rotate development/test credentials after handover as agreed.
- Do not copy session cookies across insurers.

4. Personal data

- Collect only fields needed for quoting.
- Prefer age over DOB where insurer requirements allow.
- Use dummy/sanitized data in tests and demos.
- Redact screenshots and diagnostic bundles.
- Approve retention duration and test deletion of DB rows and related evidence.
- Warn users that exported PDFs may contain sensitive data.
- No automatic upload/email of PDFs unless separately approved.

5. Insurer interaction

- Confirm portal terms and business authorization before automation.
- Never bypass CAPTCHA, reCAPTCHA, OTP, MFA, rate limits or access controls.
- Stop automation or use manual entry when blocked.

- Bound concurrency and avoid aggressive retries.

6. Logging

Log: app version, run/correlation ID, insurer ID, state transition, error category, timing and retry count. Do not log: passwords, OTPs, cookies, full census, full DOB or unredacted screenshots by default.

7. Release security gate

- [ ] Renderer/preload/main boundaries reviewed.
- [ ] IPC schema validation tested.
- [ ] Navigation/popup behavior tested.
- [ ] Secret scan clean.
- [ ] Fixtures use dummy/sanitized data.
- [ ] Logs reviewed for PII/secrets.
- [ ] Retention/deletion tested.
- [ ] Signing/update provenance verified.
- [ ] Insurer permission and legal text approved.
- [ ] Client approves disclaimer/consent and branding fields.